

The Inhibitors to Zero Trust Architecture

It seems that everyone in the information security field is talking about Zero Trust Architecture (ZTA). I certainly am.¹ Much of that conversation, so I've found, takes one of two forms. Some people tell me, "Oh, we have been Zero Trust for years." At the other extreme, I hear "ZTA is so complicated; we are taking our time figuring out if it is right for us."

The problem with the first response is that, in every discussion of which I have been a part, what the speaker really means is that they attempt to limit users' access permissions to the minimum needed to perform their jobs (i.e., least privilege). That is a step in the right direction, but they have done nothing to prevent lateral movement within their environments nor to segment their networks to map the segments to specified user groups (i.e., microsegmentation).² These are two of the key pillars of ZTA³ that enforce least privilege.

In the latter case, what I believe is actually meant is that they are trying to find the financial justification

for future security product acquisitions. This is a valid concern, but with increasing numbers of vendors announcing that their products are Zero Trust-enabled, the only question is when they will take advantage of the architecture.

So, why do I hear more talk about ZTA than I see actual implementation? In a previous article I bemoaned the term "Zero Trust" itself.⁴ There are a number of more substantive inhibitors that I'd like to discuss here.

Insecure Identity

The essential premise of Zero Trust is that users must be verified every time they attempt to access information resources, not only at the point at which they sign in. Underlying that is the assumption that an authenticated identifier can be associated with authorized resources. But what assurance is there that the user (which may or may not be a human being) that entered the identifier is actually the entity that it claims to be to be?

The use of stolen credentials to perpetrate cyberattacks has been widely reported, although the incidence of such thefts is not clear.⁵ We can say that if the validity of the identifier is suspect, verification of access rights is unavailing. To an extent, multifactor authentication (MFA) resolves that concern, but there are too many cases where stolen credentials have been used to dismiss the issue.

Overauthorization

Even if the identity of the user is valid, *should* that person have access to the requested resources? If the user has been authorized to do so, then the answer is "yes." But the literature on ZTA is largely silent on the process for granting, communicating, and enforcing access rights, simply assuming that authorization has occurred. The process of authorization is seen as external to the processes for protection, despite the fact that protection hinges on authorization. This is an issue that, as I see it, must be addressed.

STEVEN J. ROSS | CISA, CDPSE, AFBCI, MBCP

Is executive principal of Risk Masters International LLC. He has been writing one of the Journal's most popular columns since 1998. Ross was inducted into the ISACA® Hall of Fame in 2022. He can be reached at stross@riskmastersintl.com.

ZTA can protect against misuse of data but it cannot protect data that no one is aware of.

Authorization itself needs refinement because, in my experience, the authorizers have little or no formal guidance. There are many instances in which the designated managers, also referred to as data owners, are eager to provide themselves with maximum flexibility and are therefore reluctant to limit what their people can do or, as importantly, cannot do.

Also, as individuals' careers progress through an organization, they are granted access to the resources they need for their current positions, but these are often not withdrawn when they move on to their next assignments. Over time, these people have access to data and transactions they do not need (or on occasion should not have).

Weak Data Management

Limiting access to data and transactions is only meaningful if an organization knows what data it has, what it looks like, and where it is—in other words, is able to manage its data. Some enterprises have effective data management functions, but in my experience, that is limited to large companies and government agencies. Evidently, managed data is a luxury that smaller organizations cannot afford.

ZTA can protect against misuse of data but it cannot protect data that no one is aware of. This is particularly a conundrum with regard to personally identifiable information (PII). Fields such as name, address, email address, or telephone number are often extracted, replicated, transmitted, and copied from their primary databases for specialized uses. If the existence of these alternative files is not known, there is little data managers (and security managers, for that matter) can do.

Incomplete Knowledge of Applications

Just as many organizations are unaware of their data, many also do not know what application software they have. Of course, they know the applications they use most of the time. But do they know the ones used by only a limited number of users only at

certain times? Prior versions and upgrades of many application systems may have been retained for many years, because "you never know." There are those acquired by business departments, unknown to the information security function. And there is the application that only Karl knew how to maintain, and he quit seven years ago.⁶

Outdated software is not a new problem.⁷ The issue is that malicious access to these programs is less likely to be noticed than if production software were attacked, but this forgotten software can be exploited as a pathway to the current versions or to the data itself.

Everything and Anything

From all the foregoing, one might assume that I see the inhibitors as too great to overcome. But that is not the case at all. With regard to ZTA, I am not a pessimist but a realist.⁸ Yes, implementing ZTA is not easy and there are obstacles to overcome.

Note that of the four inhibitors I address, two (insecure identities and overauthorization) are not uniquely Zero Trust problems. We have been facing them for as long as I have been involved in information security and they have not stopped us from proceeding. The second two (weak data management and incomplete knowledge of applications) are shocks that information technology is heir to. If we had waited to solve these before we secured information resources, we would have no security at all.

Delaying the implementation of a security architecture that is clearly the best that has been designed so far is to say that if one cannot have everything one wants, then having nothing is preferable. This attitude, I believe, is beyond childish; it is self-defeating. I say that because in my career I have seen many threats to the security of information resources mitigated but not overcome completely. Computer viruses have been a known problem for quite a while; antivirus software has not solved it (whatever that means) but we have continued computing. Passwords have long been known to be weak protection⁹ but we still use them, with MFA increasing their effectiveness.

So go ahead and take the path towards ZTA. The road is not well paved and there may be roadblocks ahead. But getting there is a consummation devoutly to be wished.



LOOKING FOR MORE?

- Read *Zero Trust: How to Beat Adversaries at Their Own Game*. <https://www.isaca.org/zero-trust>
- Learn more about, discuss, and collaborate on information and cybersecurity in ISACA's Online Forums. <https://engage.isaca.org/onlineforums>

Endnotes

- 1 In addition to the advice I give to clients and the courses I teach, my columns in the last two issues of the *ISACA Journal* have been about aspects of the subject. Ross, S.; "Who Put the Zero in Zero Trust?" *ISACA Journal*, vol. 1, 2024, <https://www.isaca.org/archives>; Ross, S.; "Information Security Architecture: From Access Paths to Zero Trust," *ISACA Journal*, vol. 2, 2024, <https://www.isaca.org/archives>.
- 2 With apologies, these are overly simplistic definitions. Most of the literature I have found that defines the terms comes from vendors of products intended to achieve least privilege and microsegmentation. One product-agnostic source is Moosakis, C.; Fitzgibbons, L.; "Microsegmentation," TechTarget, <https://www.techtarget.com/searchnetworking/definition/microsegmentation>
- 3 *Op cit* Ross
- 4 *Op cit* Ross
- 5 The Ponemon Institute's 2023 report states that phishing and stolen or compromised credentials (which I consider to be essentially the same thing) were responsible for 16% and 15% of reported breaches, respectively. Google's 2023 *Threat Horizon* report claims that "Credential issues continue to be a consistent challenge, accounting for over 60% of compromise factors." However, the accompanying statistics show 7% of cloud compromise factors to be related to leaked credentials. Of the reported breaches, 54.8% were attributable to weak or absent passwords, which I do not consider to be the same as stolen credentials. IBM/Ponemon Institute, *Cost of a Data Breach Report 2023*, p. 20, 2023, https://www.ibm.com/reports/data-breach?utm_content=SRCWW&p1=Search&p4=43700077724064000&p5=e&gclid=EAlaIqobChM-qfcychHigwMV-2FHAR3migkMEAAYASAAEgJU0fD_BwE&gclsrc=aw.ds; Google Cloud Cybersecurity Action Team, *Threat Horizons Report 2023*, August 2023, p. 4, https://services.google.com/fh/files/blogs/gcat_threathorizons_full_jul2023.pdf
- 6 Then there are applications that can only be called dumb. I once saw iTunes on an application list, and that company was not in the music business.
- 7 Ross, S.; "Microwave Software," *ISACA Journal*, vol. 1, 2015, <https://www.isaca.org/archives>
- 8 In fact, I'd say that's true about most things.
- 9 I wrote about this matter in this space in 2001. Ross, S.; "Why Passwords Persist," *ISACA Journal*, vol. 1, 2001.

Advance Your Team Performance Today

ISACA has the enterprise team training and credentials needed to help your staff thrive today and prepare them for the business challenges of tomorrow.



Find out how your teams can benefit from ISACA training.

www.isaca.org/AdvanceYourTeam

